



**Q3**

**Map the breach to Cyber Kill Chain stages / MITRE ATT&CK**

**5 Marks**

**Objective:** Place each attacker action into the correct Cyber Kill Chain stage and, where possible, tag it with a MITRE ATT&CK technique ID.

### Step-by-Step Algorithm

| Step | Phase   | Action                                                              | Command / Tool     | What You Should See     |
|------|---------|---------------------------------------------------------------------|--------------------|-------------------------|
| 1    | SETUP   | List the seven Cyber Kill Chain stages as your framework.           | Cyber Kill Chain   | Stage list ready        |
| 2    | ANALYSE | Assign each attacker action to the stage where it belongs.          | Kill chain mapping | Action per stage        |
| 3    | ANALYSE | Look up a matching ATT&CK technique for each action.                | ATT&CK Navigator   | Technique IDs (T####)   |
| 4    | TEST    | Mark the earliest stage where detection was realistically possible. | —                  | Detection point flagged |
| 5    | REPORT  | Record the mapping as a table for the report.                       | Table template     | Kill chain table        |

Phase key: ● SETUP ● CONFIGURE ● EXECUTE ● TEST ● ANALYSE ● REPORT ● FINISH

### Worked Example (with sample values & output)

#### Kill chain and ATT&CK mapping (Acme HealthCare)

| Kill Chain stage      | Observed action             | ATT&CK technique |
|-----------------------|-----------------------------|------------------|
| Reconnaissance        | Employee emails researched  | T1591            |
| Delivery              | Phishing email sent         | T1566            |
| Exploitation          | Malicious attachment opened | T1204            |
| Installation          | Ransomware dropped          | T1486            |
| Actions on Objectives | Data exfiltrated            | T1041            |

Earliest realistic detection: the Delivery stage. An email gateway scanning attachments could have quarantined the phishing message before it ever reached the user.

### Reusable Template

**The Equifax 2017 Breach** one of the most critical cybersecurity failures in history, compromising the sensitive **Personally Identifiable Information (PII)** of approximately **147 million consumers**. The incident serves as a textbook example of systemic failure across patch management, internal network isolation, and encryption enforcement

#### Kill chain mapping template (copy and fill)

| Kill Chain stage      | Observed action                                                                                | ATT&CK technique (optional)    |
|-----------------------|------------------------------------------------------------------------------------------------|--------------------------------|
| <b>Reconnaissance</b> | Scanned Equifax's public-facing servers looking for unpatched web application vulnerabilities. | <b>T1595</b> (Active Scanning) |



| Kill Chain stage             | Observed action                                                                                                            | ATT&CK technique (optional)                                                   |
|------------------------------|----------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| <b>Weaponization</b>         | Compiled an exploit payload targeting a known remote code execution flaw in Apache Struts.                                 | <b>T1587</b> (Develop Capabilities)                                           |
| <b>Delivery</b>              | Sent the crafted HTTP request containing the malicious payload directly to the Equifax portal.                             | <b>T1190</b> (Exploit Public-Facing Application)                              |
| <b>Exploitation</b>          | <b>[EARLIEST DETECTION POINT]</b> The server processed the header, executing systemic commands with web-server privileges. | <b>T1210</b> (Exploitation of Remote Services)                                |
| Installation                 | Installed web shells on the compromised servers to maintain a persistent back door.                                        | T1505.003 (Server Software Component: Web Shell)                              |
| <b>Command &amp; Control</b> | Communicated with the web shells using encrypted channels to blend in with normal web traffic.                             | <b>T1071.001</b> (Application Layer Protocol: Web Protocols)                  |
| <b>Actions on Objectives</b> | Conducted internal database queries, found unencrypted credentials, and exfiltrated data over 146 days.                    | <b>T1020</b> (Automated Exfiltration) / <b>T1115</b> (Data from Local System) |

**Your Output / Screenshot (paste result here):**

- **Threat Actor:** Publicly attributed by the U.S. Department of Justice to four members of China's People's Liberation Army (PLA).
- **Primary Entry Point:** An unpatched remote code execution vulnerability (**CVE-2017-5638**) in the **Apache Struts** framework handling the credit dispute web portal.
- **Dwell Time:** The attackers maintained unauthorized access inside Equifax's internal corporate environment for **76 days** (from May 13 to July 29, 2017).
- **Exploitation Scope:** Due to a flat network topology, the attackers pivoted away from the initial application server to run **9,000 queries across 48 internal databases**, finding unencrypted database credentials stored directly within internal configuration files.
- **The Blind Spot:** Data exfiltration occurred over encrypted channels completely unmonitored by security teams because Equifax had **neglected to renew an expired SSL visibility certificate** for nearly 10 months. Intrusion detection systems only flagged the theft when the certificate was finally updated on July 29